# LLM-HyPZ: Hardware Vulnerability Discovery using an LLM-Assisted Hybrid Platform for Zero-Shot Knowledge Extraction and Refinement

Yu-Zheng Lin*, Sujan Ghimire*, Abhiram Nandimandalam‡, Jonah Michael Camacho*, Unnati Tripathi†, Rony Macwan‡, Sicong Shao¶, Setareh Rafatirad‖, Rozhin Yasaei‡, Pratik Satam*†, and Soheil Salehi*

*Department of Electrical and Computer Engineering, University of Arizona, Tucson, AZ, USA
†Department of Systems and Industrial Engineering, University of Arizona, Tucson, AZ, USA
‡College of Information Science, University of Arizona, Tucson, AZ, USA
¶School of Electrical Engineering and Computer Science, University of North Dakota, Grand Forks, ND, USA
‖ Department of Computer Science, University of California Davis, CA, USA
Email: {*yuzhenglin,*sghimire,‡abhiramn,*jonahcamacho,†utripathi,‡ronymacwan,‡yasaei,†*pratiksatam,*ssalehi} @arizona.edu; ¶sicong.shao@und.edu; ‖srafatirad@ucdavis.edu

***Abstract*—The rapid growth of hardware vulnerabilities has created an urgent need for systematic and scalable analysis methods. Unlike software flaws, which are often patchable post-deployment, hardware weaknesses remain embedded across product lifecycles, posing persistent risks to processors, embedded devices, and IoT platforms. Existing efforts such as the MITRE CWE Hardware List (2021) rely on expert-driven Delphi surveys, which lack statistical rigor and introduce subjective bias, while large-scale data-driven foundations for hardware weaknesses are largely absent. In this work, we propose LLM-HyPZ, an LLM-assisted hybrid framework for zero-shot knowledge extraction and refinement from vulnerability corpora. Our approach integrates zero-shot LLM classification, contextualized embeddings, unsupervised clustering, and prompt-driven summarization to mine hardware-related CVEs at scale. Applying LLM-HyPZ to the 2021–2024 CVE corpus (114,836 entries), we identified 1,742 hardware-related vulnerabilities. We distilled them into five recurring themes, including privilege escalation via firmware and BIOS, memory corruption in mobile and IoT systems, and physical access exploits. Benchmarking across seven LLMs shows that LLaMA 3.3 70B achieves near-perfect classification accuracy (99.5%) on a curated validation set. Beyond methodological contributions, our framework directly supported the MITRE CWE Most Important Hardware Weaknesses (MIHW) 2025 update by narrowing the candidate search space. Specifically, our pipeline surfaced 411 of the 1,026 CVEs used for downstream MIHW 2025 analysis, thereby reducing expert workload and accelerating evidence gathering. These results establish LLM-HyPZ as the first data-driven, scalable approach for systematically discovering hardware vulnerabilities, thereby bridging the gap between expert knowledge and real-world vulnerability evidence.**

***Index Terms*—Large Language Models, Hardware Security, Data Mining, Contextualized Embedding, Topic Modeling**

## I. Introduction

The increasing complexity and integration of modern computing platforms have amplified concerns surrounding hardware vulnerabilities, encompassing physical components, micro-architectural features [1], and system-level integrations such as firmware interfaces and heterogeneous computing platforms [2, 3]. Unlike software flaws, which can often be mitigated through post-deployment patches, hardware weaknesses are typically embedded in various stages of chip design, persisting throughout the lifecycle of deployed systems. These latent flaws expose processors, embedded devices, and Internet-of-Things (IoT) platforms to long-term risks, with potential consequences ranging from privilege escalation to denial-of-service attacks. Because remediation after deployment is often infeasible, these vulnerabilities remain entrenched across product lifecycles, posing systemic risks to both consumer and industrial domains. As the ecosystem of connected and heterogeneous devices expands, the number of reported hardware-related vulnerabilities has markedly increased in recent years, underscoring the urgent need for systematic approaches to their identification, classification, and mitigation.

Recognizing the importance of systematic classification, MITRE released the Common Weakness Enumeration (CWE) Hardware List in 2021 to highlight critical hardware weaknesses [4]. However, its construction relied on a modified Delphi process, where experts subjectively ranked weaknesses according to survey questions on prevalence, exploitability, and mitigation difficulty. While expert judgment offers valuable insights, this approach is inherently constrained: it lacks statistical rigor, introduces potential biases, and does not directly reflect the empirical distribution of vulnerabilities reported in the field. In contrast, the well-established CWE Top 25 for software is data-driven, leveraging frequency and severity statistics from the Common Vulnerabilities and Exposures (CVE) and the National Vulnerability Database (NVD). A comparable quantitative foundation has been absent for hardware vulnerabilities, largely due to the limited mapping between CVEs and CWEs in the hardware domain.

Meanwhile, the CVE corpus has expanded exponentially, now exceeding 100,000 entries with an increasing share involving hardware-level issues. As illustrated in Figure 1, CVE reports have accelerated sharply over the past decade, particularly from 2017 to 2024, offering a rich source of

2375-9259/25/$31.00 ©2025 IEEE
DOI 10.1109/ICDMW69685.2025.00150

real-world evidence for uncovering systemic design flaws. Yet this corpus simultaneously poses significant analytical challenges: large scale, semantic ambiguity, and inconsistent terminology hinder robust classification. Descriptions often conflate hardware, firmware, and software, omit technical specifics, or use vague descriptors, complicating automated identification of hardware-related vulnerabilities. Prior studies confirm these limitations, showing that CVE-based analyses frequently struggle with categorization due to sparse labeling, inconsistent metadata, and context-dependent terminology [3, 5–8]. As a result, extracting hardware-relevant vulnerabilities and identifying recurring patterns within CVEs remains an unresolved challenge for establishing scalable, systematic security analysis.

The rapid advancement of Large Language Models (LLMs) has transformed data mining by enabling scalable and interpretable knowledge extraction in domains where labeled data is scarce or contextually ambiguous. Traditional approaches often rely on handcrafted features or supervised pipelines [9], which are constrained by annotation bottlenecks and domain-specific expertise. In contrast, LLMs demonstrate deep contextual understanding of natural language and exhibit strong generalization across tasks without requiring task-specific fine-tuning. Their zero-shot reasoning abilities allow them to perform classification, clustering, and summarization with minimal supervision, thereby lowering the barrier for high-quality data mining in complex textual domains [10–12]. In cybersecurity, where the scale and diversity of vulnerability reports such as CVE continue to grow rapidly [13], these capabilities of LLMs provide a promising foundation to extract patterns, reveal latent themes, and support scalable security analysis [14]. To address the specific challenges of large-scale hardware vulnerability discovery under limited supervision, we propose LLM-HyPZ (LLM-Assisted Hybrid Platform for Zero-Shot Knowledge Extraction and Refinement). This three-stage framework integrates zero-shot classification, contextualized embeddings, and unsupervised clustering. The LLM-HyPZ pipeline begins with prompt-engineered LLMs that perform zero-shot classification of CVE entries, filtering hardware-related vulnerabilities from a corpus of over 100,000 entries reported between 2021 and 2024. The selected hardware CVEs are then represented as high-dimensional semantic vectors using the OpenAI text-embedding-3-large model (3072 dimensions), capturing contextual meaning across diverse vulnerability descriptions. These embeddings are clustered using K-means, with the number of clusters selected via the Elbow method to balance model complexity and cohesion. To ensure interpretability, each cluster undergoes frequency-based n-gram extraction [15–17], followed by prompt-driven summarization with GPT5, which generates concise topic labels rooted in hardware security terminology.

After applying this systematic pipeline to the 2021–2024 CVE corpus, we identified 1,742 potential hardware-related vulnerabilities, which were distilled into five topics. The experimental results demonstrate that LLM-HyPZ can uncover coherent vulnerability clusters and generate interpretable topic labels without requiring labeled training data. This work thus provides the first data-driven perspective on systemic hardware risks derived from real-world vulnerability reports, addressing the limitations of expert-driven methodologies such as the modified Delphi approach in MITRE MIHW 2021 and establishing a scalable foundation for systematic hardware weakness classification.

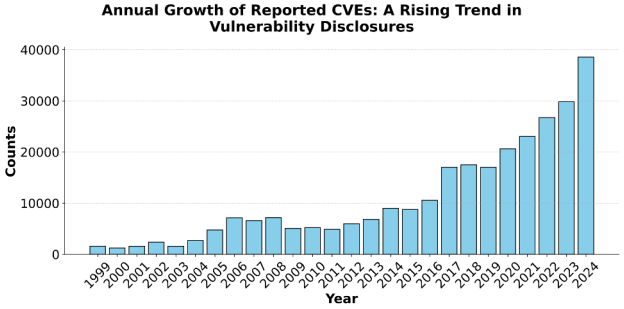



Fig. 1: Annual Growth of Reported CVEs: A Rising Trend in Vulnerability Disclosures

## II. Related Work

Recent advances in data-driven cybersecurity have led to a growing interest in automated methods for extracting and organizing insights from large-scale vulnerability datasets. Prior research has explored diverse strategies to address the challenges posed by unstructured CVE descriptions, ranging from traditional rule-based systems to modern machine learning and language modeling approaches. In this section, we review related efforts across two key areas: large-scale vulnerability mining and the use of large language models (LLMs) for data mining tasks.

### *A. Large-Scale Vulnerability Knowledge Discovery in CVE Database*

With the rapid growth of CVE entries, prior research has explored rule-based extraction of structured identifiers (e.g., CPEs), topic modeling over vulnerability texts, and sequence labeling for component recognition. Bhurtel and Rawat [18] curated OS-specific datasets enriched with CPE, CVSS, and CWE attributes to analyze severity trends across platforms such as Windows and Android. Neuhaus and Zimmermann [19] applied latent Dirichlet Allocation (LDA) to uncover temporal vulnerability themes without relying on fixed CWE taxonomies. Wåreus et al. [7] leveraged Bi-LSTM+CRF models to predict CPE components from unstructured CVE summaries. While effective, these approaches suffer from brittle heuristics, limited semantic granularity, or heavy reliance on labeled data. Moreover, most efforts focus on software vulnerabilities, leaving hardware largely underexplored. In contrast, large language models (LLMs) with contextualized embeddings enable zero/few-shot generalization and semantic-level analysis, providing a more adaptive framework for scalable vulnerability mining.

### *B. LLM-Based Data Mining*

Recent advances in large language models (LLMs) enable scalable, minimally supervised knowledge extraction from

unstructured text, contrasting with rule-based or heavily supervised methods that require expert knowledge and labels. Prior work demonstrates their utility across domains: Mallen et al. [20] integrate LLMs with dense retrieval for scientific knowledge graphs; Fink et al. [11] apply prompt-based pipelines to mine oncologic features from CT reports; and Wan et al. [21] introduce TnT-LLM, combining taxonomy induction with zero-shot classification. These frameworks highlight the potential of LLMs for flexible and interpretable text mining at scale. However, in cybersecurity reports and databases, their adoption remains nascent. For this study, the CVE database serves as the primary target. However, CVE descriptions often conflate software, firmware, and hardware elements, making precise categorization difficult. To address this challenge, our work combines zero-shot LLM classification with contextual embeddings and unsupervised clustering to scalably extract hardware-related vulnerabilities from large unlabeled corpora.

## III. Framework

To address the growing scale and semantic ambiguity of vulnerability databases, we propose LLM-HyPZ, a three-stage data mining framework that leverages LLMs and contextualized embedding techniques to facilitate a structured understanding of hardware-related CVEs. As illustrated in Figure 2, LLM-HyPZ integrates zero-shot classification, contextualized embedding, unsupervised clustering, and an LLM-based summarizer to allow scalable exploration and interpretation of large vulnerability corpora.

In Stage 1, a task specific prompt guides a large language model (LLM) to act as a zero-shot classifier, separating candidate vulnerability descriptions into hardware- and software-related lists. In Stage 2, the hardware-related descriptions are embedded using a contextualized word embedding model, followed by K-Means clustering to extract latent semantic patterns. Stage 3 employs word frequency analysis and LLM-based summarization to interpret each cluster, producing both structured reports and visual representations of key knowledge patterns. LLM-HyPZ enables domain experts to identify thematic trends and common characteristics across hardware vulnerabilities without the need for large labeled datasets, offering a scalable, language-driven solution for early-stage vulnerability mining. Algorithm 1 presents the end-to-end procedure of the proposed LLM-HyPZ framework.

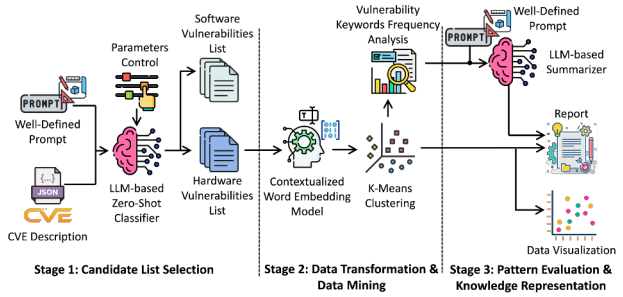



Fig. 2: LLM-HyPZ: LLM-Assisted Hybrid Platform for Zero-Shot Knowledge Extraction and Refinement

**Algorithm 1** LLM-HyPZ: Zero-shot Mining of Hardware Vulnerabilities from CVEs

**Require:** CVE corpus $\mathcal{D}_{\text{CVE}} = \{d_i\}_{i=1}^{n}$; classifier LLM $\mathcal{M}_{\text{cls}}$; summarizer LLM $\mathcal{M}_{\text{sum}}$; HW/SW classification prompt $\rho_{\text{HW/SW}}$; summary prompt $\rho_{\text{sum}}$; embedding model $\phi : \mathcal{X} \to \mathbb{R}^{d_\phi}$; $K$ or a selection rule (e.g., Elbow); top-$r$ n-grams.

**Ensure:** Hardware set $\mathcal{X}_{\text{HW}}$; embeddings $\mathcal{V}_{\text{HW}}$; clusters $\{C_k\}_{k=1}^{K}$; topic labels $\{T_k\}_{k=1}^{K}$.

$\mathcal{X}_{\text{HW}} \leftarrow \emptyset$
**for** $i = 1$ **to** $N$ **do**
  $z_i \leftarrow \mathcal{M}_{\text{cls}}\big([\rho_{\text{HW/SW}}; d_i]\big)$ ▷ $z_i \in \{0, 1\}$
  **if** $z_i = 1$ **then**
    $\mathcal{X}_{\text{HW}} \leftarrow \mathcal{X}_{\text{HW}} \cup \{d_i\}$
  **end if**
**end for**
$\mathcal{V}_{\text{HW}} \leftarrow \{\phi(x) \mid x \in \mathcal{X}_{\text{HW}}\}$ ▷ Contextual embeddings
**if** $K$ not provided **then**
  $K \leftarrow SelectKByElbow(\mathcal{V}_{\text{HW}})$
**end if**
$\{C_k\}_{k=1}^{K}, \{\boldsymbol{\mu}_k\}_{k=1}^{K} \leftarrow KMeans(\mathcal{V}_{\text{HW}}, K)$ ▷ initialized with K-Means++ for stable centroids
**for** $k = 1$ **to** $K$ **do**
  $\mathcal{W}_k \leftarrow TopNGrams\big(\{x \mid \phi(x) \in C_k\}, r\big)$ ▷ uni/bi/tri-grams
  $T_k \leftarrow \mathcal{M}_{\text{sum}}\big([\rho_{\text{sum}}; \mathcal{W}_k]\big)$ ▷ Topic summarize
**end for**
**return** $\mathcal{X}_{\text{HW}}, \mathcal{V}_{\text{HW}}, \{C_k\}_{k=1}^{K}, \{T_k\}_{k=1}^{K}$

### A. Candidate List Selection

This Figure 3 illustrates a comparative view of the traditional and proposed pipelines to identify hardware-relevant CVEs. In the traditional workflow, candidate CVEs are filtered through predefined rules and subsequently subjected to human review, resulting in limited scalability and difficulty handling semantic ambiguity. In contrast, our proposed method introduces a human-in-the-loop paradigm augmented by a Large Language Model (LLM) conditioned with expert-guided prompts [22]. The LLM performs semantic filtering and data discovery to surface candidate vulnerabilities likely related to hardware. In this process, humans will analyze, provide feedback, and validate the model's insights to improve the guidance prompt for LLM. The inclusion of human feedback contributes to a more adaptive and interpretable vulnerability classification system.

To select candidates for further analysis, we employ a binary classification approach using an LLM with prompt engineering. Specifically, we aim to classify entries in the vulnerability dataset $\mathcal{D}_{\text{CVE}} = \{d_1, d_2, \ldots, d_n\}$, where each $d_i$ represents a CVE record. The objective is to identify whether a given CVE pertains to hardware (1) or software (0). For each CVE entry $d$, we construct a specialized prompt $\rho_{\text{HW/SW}}$ that describes the classification task and provides label context. The input to the LLM is the concatenation of the prompt and the CVE description, denoted as $[\rho_{\text{HW/SW}}; d]$. The model $\mathcal{M}$ then outputs a predicted label $\hat{y}_i = \mathcal{M}([\rho_{\text{HW/SW}}; d_i], p_{\text{top}}, \tau) \in \{0, 1\}$, where $p_{\text{top}}$ denotes the top-$p$ nucleus sampling

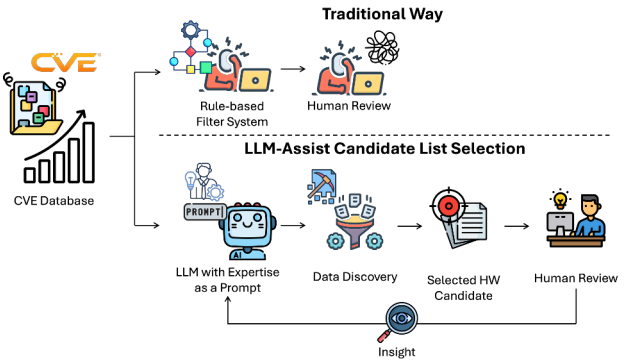



Fig. 3: LLM-Assisted vs. Rule-Based Pipelines: A Comparative View for Classifying Task in Large-Scale Vulnerability Databases

threshold, and $\tau$ is the temperature parameter controlling the randomness of generation. This zero-shot inference efficiently filters out non-hardware CVEs without supervised training, enabling scalable pre-screening for hardware-focused security analysis.

### B. Contextualized Word Embedding

Following the binary classification stage, we isolate CVE entries predicted as hardware-related ($\hat{y} = 1$) for further representation learning. Let the set of hardware-related CVE texts be denoted as $\mathcal{X}_{\text{HW}} = \{x_i \in \mathcal{X} \mid \hat{y}_i = 1\}$. For each $x_i \in \mathcal{X}_{\text{HW}}$, we compute a high-dimensional contextual embedding using the embedding model $\phi : x \to \mathbb{R}^{d_\phi}$, where $d_\phi$ is the embedding dimensionality. Formally, the contextualized embedding for each hardware CVE is defined as $\mathbf{v}_i = \phi(x_i)$ with $\mathbf{v}_i \in \mathbb{R}^{d_\phi}$. This representation captures semantic information about the vulnerability in a vector space. The resulting set of embeddings $\mathcal{V}_{\text{HW}} = \{\mathbf{v}_i\}_{i=1}^{|\mathcal{X}_{\text{HW}}|}$ serves as the foundation for downstream analysis.

### C. Clustering Hardware Vulnerabilities with K-Means

To uncover latent structures within hardware-related vulnerabilities, we apply K-means clustering [23] on the set of contextualized embeddings $\mathcal{V}_{\text{HW}} = \{\mathbf{v}_i\}_{i=1}^{N}$, where each $\mathbf{v}_i \in \mathbb{R}^{d_\phi}$. K-means partitions the embedding space into $K$ disjoint clusters $\{C_1, \ldots, C_K\}$ by minimizing the objective function $\sum_{k=1}^{K} \sum_{\mathbf{v}_i \in C_k} \|\mathbf{v}_i - \boldsymbol{\mu}_k\|^2$, where the centroid of cluster $C_k$ is defined as $\boldsymbol{\mu}_k = \frac{1}{|C_k|} \sum_{\mathbf{v}_i \in C_k} \mathbf{v}_i$. The Elbow Method is used to estimate an optimal $K$, balancing model complexity and cluster cohesion. The resulting clusters reveal semantically coherent groupings of hardware CVEs, each potentially capturing a distinct vulnerability theme (e.g., firmware bugs, physical interface flaws, or microarchitectural exploits), and serve as interpretable units for downstream analysis in the hardware security domain.

### D. Cluster Summarization via LLM with Prompt-based Concept Extraction

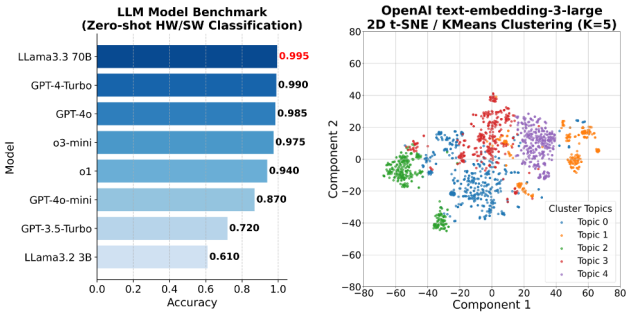
After clustering, we aim to generate concise semantic summaries for each cluster by leveraging an LLM $\mathcal{M}$ through prompt-based reasoning. For each cluster $C_k$, we extract the top-$r$ most frequent n-grams (including bigrams and trigrams) from the CVE descriptions within the cluster, forming a representative words set $\mathcal{W}_k = \{w_1, w_2, \ldots, w_r\}$. We then define a fixed summarization prompt $\rho_{\text{sum}}$, whose role is to guide the LLM toward producing concise, domain-specific topic descriptors. The input to the LLM is the concatenation $[\rho_{\text{sum}}; \mathcal{W}_k]$. The output is a cluster-level topic summary $T_k$, formally defined as $T_k = \mathcal{M}([\rho_{\text{sum}}; \mathcal{W}_k])$, where $\mathcal{M}$ generates a natural language summary grounded in the statistical distribution of terms within the cluster. Unlike the classification setting described in our testing task $\mathcal{D}_{\text{CVE}}$, where the input was $[\rho; d]$, here the input omits full CVE descriptions and instead focuses on high-signal lexical patterns aggregated over multiple instances. This summarization procedure enables interpretable, high-level characterizations of clusters in the absence of explicit labels. It also supports downstream applications such as threat taxonomization, expert annotation, or search-based retrieval based on inferred vulnerability.

## IV. Experiments

### A. LLM performance comparison on validation dataset

We consider a validation task specified by a dataset $\mathcal{D}_{\text{CVE_Validation}} = \{(d_i, y_i)\}_{i=1}^{N}$, where each example consists of a CVE description $d_i$ and a binary label $y_i \in \{0, 1\}$ indicating whether the vulnerability is hardware-related ($y_i = 1$) or software-related ($y_i = 0$). In our setting, the dataset contains $N = 200$ manually labeled samples, with 100 hardware-related and 100 software-related CVEs selected from the public CVE database. Details of $\mathcal{D}_{\text{CVE_Validation}}$ are provided in Appendix A of our pre-print [24]. Our objective is to benchmark the performance of different large language models $\mathcal{M}$ on this binary classification task. Given a fixed instruction $\rho$, we evaluate how well $\mathcal{M}$ predicts the correct label $\hat{y}_i \in \{0, 1\}$ when prompted with the concatenation $[\rho_{\text{HW/SW}}; d_i]$, for each $(d_i, y_i) \in \mathcal{D}_{\text{CVE_Validation}} = \{(d_i, y_i)\}_{i=1}^{N}$. We define the model's performance using **Accuracy**, computed as Accuracy $= \frac{TP+TN}{TP+TN+FP+FN}$, where $TP$, $TN$, $FP$, and $FN$ denote true positives, true negatives, false positives, and false negatives, respectively.

The HW/SW classification prompt ($\rho_{\text{HW/SW}}$) defined with persona, reflection and template pattern [25], which follows the $\rho_{\text{HW/SW}}$ defined in our pre-print [24]. The temperature parameter to $\tau = 0.6$ and the nucleus sampling threshold to $p_{\text{top}} = 0.2$. Figure 4 reports the accuracy of large language models $\mathcal{M}$ on the zero-shot HW/SW classification task defined in $\mathcal{D}_{\text{CVE_Validation}}$. All models were evaluated under identical prompt conditions using the fixed instruction $\rho_{\text{HW/SW}}$ and default parameters. The OpenAI models were accessed via the official API [26], while the LLaMA series was obtained through the AI Verde platform [27]. Results indicate that comparatively newer models, including `LLaMA3.3 70B`, `GPT-4-Turbo`, and `GPT-4o`, achieve near-perfect accuracy, whereas smaller or earlier models, such as `GPT-3.5-Turbo` and `LLaMA3.2 3B`, achieve lower accuracies of 0.72 and 0.61. This underscores the impact of model scale and architectural progression on performance.




(a) (b)

Fig. 4: From model benchmarking to clustering analysis of hardware-related vulnerabilities. (a) Benchmarking LLMs on zero-shot HW/SW classification. (b) K-means clustering with t-SNE visualization of hardware-related CVEs identified by the top model (Llama3.3 70B).

### *B. Discovering Hardware Vulnerability Topics in the 2021–2024 CVE Corpus Using LLM-HyPZ*

Building upon the benchmark results, we applied the best-performing model, `LLaMA 3.3 70B`, to perform large-scale inference on the complete CVE corpus from 2021 to 2024. This dataset contains 114,836 publicly disclosed CVE entries, from which we identified 1,742 entries predicted as hardware-related by the classifier under the zero-shot prompt.

After obtaining the hardware-related CVEs from 2021 to 2024, we began by embedding the 1,742 candidate CVE descriptions using the OpenAI model `text-embedding-large`, resulting in contextualized semantic vectors suitable for downstream clustering. K-means clustering was then applied, with the number of clusters set to $k = 5$, as determined by the Elbow Method [28]. To uncover the semantics within each cluster, we performed an n-gram frequency analysis over the CVE descriptions, extracting the top 15 most frequent uni-, bi-, and tri-grams. These keywords revealed prominent lexical patterns associated with distinct categories of hardware vulnerabilities, and the keyword distributions exhibited clear distinctions between clusters.

TABLE I: Top 15 n-gram keywords and LLM-generated topic summaries with GPT5 of five clusters.

| Topic | Top 15 Keywords | LLM-based Topic Summary |
|---|---|---|
| $T_0$ | access, local, user, privileged, privileged user, firmware, privilege, escalation, escalation privilege, bios, service, denial service, denial, local access, user enable | Physical Access Exploitation of Firmware and Hardware Control |
| $T_1$ | iot, modem, mobile, memory, connectivity, auto, consumer, industrial, industrial iot, memory corruption, corruption, compute, security, data, attack | Memory Corruption in IoT and Mobile Connectivity Systems |
| $T_2$ | access, device, information, physical, service, firmware, data, control, denial, user, authentication, hardware, security, confidentiality, attack | Insecure Physical and Firmware Access Leading to Confidentiality and Availability Compromise |
| $T_3$ | memory, access, execution, information, user, service, corruption, local, denial, read, data, disclosure, code, information disclosure, arbitrary | Memory Access and Corruption Leading to Arbitrary Code Execution and Information Disclosure |
| $T_4$ | access, exploit, arbitrary, disclosure, privileges, firmware, vulnerabilities, escalation, bios, code, execution, service, denial, denial service, information | Firmware Privilege Escalation and Denial-of-Service via BIOS Exploitation |

TABLE II: Representative CVEs Closest to Cluster Centroids Based on Semantic Similarity

| Topic 0 | Topic 1 | Topic 2 | Topic 3 | Topic 4 |
|---|---|---|---|---|
| CVE-2021-0091 | CVE-2021-1892 | CVE-2021-33478 | CVE-2021-26372 | CVE-2022-23924 |
| CVE-2021-0154 | CVE-2021-1948 | CVE-2022-0183 | CVE-2021-26402 | CVE-2022-23925 |
| CVE-2021-0158 | CVE-2021-30341 | CVE-2022-25831 | CVE-2021-33626 | CVE-2022-23926 |
| CVE-2021-0187 | CVE-2022-25682 | CVE-2023-20589 | CVE-2021-46764 | CVE-2022-23927 |
| CVE-2022-26006 | CVE-2022-25695 | CVE-2023-21513 | CVE-2022-23820 | CVE-2022-23928 |
| CVE-2022-26837 | CVE-2022-25724 | CVE-2023-47616 | CVE-2022-23821 | CVE-2022-23930 |
| CVE-2022-32766 | CVE-2022-25727 | CVE-2023-52101 | CVE-2023-31342 | CVE-2022-23931 |
| CVE-2022-33894 | CVE-2023-26497 | CVE-2024-21483 | CVE-2023-31343 | CVE-2022-23932 |
| CVE-2023-22449 | CVE-2023-41111 | CVE-2024-53651 | CVE-2023-31345 | CVE-2022-23933 |
| CVE-2023-43758 | CVE-2023-41112 | CVE-2024-53832 | CVE-2022-39854 | CVE-2022-23934 |

Building on these statistical patterns, we remove noise such as brand and product names, and use the summarization procedure described in Section III-D to generate concise, interpretable topic labels.For each cluster $C_k$, the corresponding n-gram set $\mathcal{W}_k$ was appended to the fixed prompt $\rho_{\text{sum}}$, which follows $\rho_{\text{sum}}$ defined in our pre-print [24], and then input to the large language model $\mathcal{M}$ (GPT-5). The model produced topic summaries $T_k$ that abstracted root causes using accurate domain-relevant terminology. The five resulting topics are shown in Table I. We further visualized the clustering structure using t-distributed stochastic neighbor embedding (t-SNE) [29], which projected the high-dimensional vectors into two dimensions. As shown in Figure 4b, each point corresponds to a CVE and is color-coded by its cluster assignment.

Lastly, to provide concrete examples of each cluster, we identified ten representative CVE entries closest to the cluster centroids based on cosine similarity in the embedding space. These entries are listed in Table II, which provides insight into the dominant patterns underlying each topic.

## V. Conclusion

In this work, we presented LLM-HyPZ, a hybrid framework that leverages large language models and contextualized embeddings for zero-shot classification and clustering, enabling large-scale mining of cybersecurity corpora. Our experimental results demonstrate that the framework can effectively identify and organize hardware vulnerabilities into semantically coherent clusters without requiring labeled data, offering a scalable alternative to expert-driven methodologies.

Importantly, this framework directly supported the CWE Most Important Hardware Weaknesses (MIHW) 2025 update [30]. By applying LLM-HyPZ to the CVE corpus from 2021–2024, we systematically narrowed down the search space for human experts. Our method filtered and candidate CVEs, enabling reviewers to focus on a tractable subset.After human validation, 1,026 CVE records were selected as the basis for downstream analysis in the MIHW process, and our contribution accounts for 411 of these. In other words, our pipeline directly surfaced 411 of the 1,026 CVEs incorporated into the MIHW 2025 workflow, thus reducing expert effort and accelerating evidence gathering. This demonstrates the value of AI-assisted data collection and analysis in establishing a

more rigorous and scalable foundation for the MIHW selection process, complementing expert knowledge with data-driven evidence. A detailed list of the identified HW CVE records can be found in Appendix B of our pre-print [24].

Despite these strengths, several limitations remain. First, CVE entries often blur hardware, firmware, and software boundaries, creating nontrivial ambiguity that still requires human validation in borderline cases. Second, reliance on large models such as `LLaMA-3.3-70B` and `GPT-4o` incurs high computational and financial costs, hindering large-scale deployment. Third, the fixed-cluster assumption in our method may not reflect the evolving taxonomy of hardware weaknesses. Future work will address these issues by exploring ensemble classification (e.g., majority voting across LLMs), multi-label and hierarchical schemes for hybrid vulnerabilities, and document-level zero-shot classification for finer granularity. We also plan to develop lightweight inference pipelines to balance accuracy with efficiency, supporting scalable integration of LLM-assisted mining with community standards such as CWE for sustainable, interpretable hardware security analysis.

## Acknowledgment

This work was partially supported by the National Science Foundation (NSF) under research project 2335046, the AI-HDL competition hosted by the University of Arizona, and the OpenAI Researcher Access Program 0000011862. We would like to thank Intel researchers Jason Fung, Arun Kanuparthi, and Hareesh Khattri for their valuable expert insights, which greatly informed the development of this work. The authors also acknowledge the MITRE CWE MIHW 2025 working group for their support and collaboration. Finally, we gratefully recognize the AI Verde team at the University of Arizona Data Science Institute for their support and resources.

## References

[1] N. Potlapally, "Hardware security in practice: Challenges and opportunities," in *2011 IEEE International Symposium on Hardware-Oriented Security and Trust*. IEEE, 2011, pp. 93–98.

[2] K. Rosenfeld and R. Karri, "Attacks and defenses for jtag," *IEEE Design & Test of Computers*, vol. 27, no. 1, pp. 36–47, 2010.

[3] I. Bojanova, "Comprehensively labeled weakness and vulnerability datasets via unambiguous formal bugs framework specifications," *IT Professional*, vol. 26, no. 1, pp. 60–68, 2024.

[4] MITRE, "2021 cwe most important hardware weaknesses," Aug 2021. [Online]. Available: https://cwe.mitre.org/topHW/archive/2021/2021_CWE_MIHW.html

[5] G. Dessouky, D. Gens, P. Haney, G. Persyn, A. Kanuparthi, H. Khattri, J. M. Fung, A.-R. Sadeghi, and J. Rajendran, "{HardFails}: insights into {software-exploitable} hardware bugs," in *28th USENIX Security Symposium (USENIX Security 19)*, 2019, pp. 213–230.

[6] Q. Chen, L. Bao, L. Li, X. Xia, and L. Cai, "Categorizing and predicting invalid vulnerabilities on common vulnerabilities and exposures," in *2018 25th Asia-Pacific Software Engineering Conference (APSEC)*. IEEE, 2018, pp. 345–354.

[7] E. Wåreus and M. Hell, "Automated cpe labeling of cve summaries with machine learning," in *Detection of Intrusions and Malware, and Vulnerability Assessment: 17th International Conference, DIMVA 2020, Lisbon, Portugal, June 24–26, 2020, Proceedings 17*. Springer, 2020, pp. 3–22.

[8] S. Yitagesu, Z. Xing, X. Zhang, Z. Feng, X. Li, and L. Han, "Unsupervised labeling and extraction of phrase-based concepts in vulnerability descriptions," in *2021 36th IEEE/ACM International Conference on Automated Software Engineering (ASE)*. IEEE, 2021, pp. 943–954.

[9] M.-S. Chen, J. Han, and P. S. Yu, "Data mining: an overview from a database perspective," *IEEE Transactions on Knowledge and data Engineering*, vol. 8, no. 6, pp. 866–883, 2002.

[10] T. Kojima, S. S. Gu, M. Reid, Y. Matsuo, and Y. Iwasawa, "Large language models are zero-shot reasoners," *Advances in neural information processing systems*, vol. 35, pp. 22 199–22 213, 2022.

[11] M. A. Fink, A. Bischoff, C. A. Fink, M. Moll, J. Kroschke, L. Dulz, C. P. Heußel, H.-U. Kauczor, and T. F. Weber, "Potential of chatgpt and gpt-4 for data mining of free-text ct reports on lung cancer," *Radiology*, vol. 308, no. 3, p. e231362, 2023.

[12] R. Tang, X. Han, X. Jiang, and X. Hu, "Does synthetic data generation of llms help clinical text mining?" *arXiv preprint arXiv:2303.04360*, 2023.

[13] R. Khoury, B. Vignau, S. Hallé, A. Hamou-Lhadj, and A. Razgallah, "An analysis of the use of cves by iot malware," in *Foundations and Practice of Security: 13th International Symposium, FPS 2020, Montreal, QC, Canada, December 1–3, 2020, Revised Selected Papers 13*. Springer, 2021, pp. 47–62.

[14] S. Ghimire, Y.-Z. Lin, M. Mamun, M. A. Chowdhury, F. Alemi, S. Cai, J. Guo, M. Zhu, H. Li, B. Saber Latibari *et al.*, "Hwrex: Ai-enabled hardware weakness and risk exploration and storytelling framework with llm-assisted mitigation suggestion," *ACM Transactions on Design Automation of Electronic Systems*, 2025.

[15] P. Satam and S. Hariri, "Wids: An anomaly based intrusion detection system for wi-fi (ieee 802.11) protocol," *IEEE Transactions on Network and Service Management*, vol. 18, no. 1, pp. 1077–1091, 2020.

[16] P. Satam, S. Satam, and S. Hariri, "Bluetooth intrusion detection system (bids)," in *2018 IEEE/ACS 15th International Conference on Computer Systems and Applications (AICCSA)*. IEEE, 2018, pp. 1–7.

[17] P. Satam, H. R. Alipour, Y. B. Al-Nashif, and S. Hariri, "Anomaly behavior analysis of dns protocol." *J. Internet Serv. Inf. Secur.*, vol. 5, no. 4, pp. 85–97, 2015.

[18] M. Bhurtel and D. B. Rawat, "Unveiling the landscape of operating system vulnerabilities," *Future Internet*, vol. 15, no. 7, p. 248, 2023.

[19] S. Neuhaus and T. Zimmermann, "Security trend analysis with cve topic models," in *2010 IEEE 21st International Symposium on Software Reliability Engineering*. IEEE, 2010, pp. 111–120.

[20] Y. Zhang, R. Yang, X. Xu, R. Li, J. Xiao, J. Shen, and J. Han, "Teleclass: Taxonomy enrichment and llm-enhanced hierarchical text classification with minimal supervision," in *Proceedings of the ACM on Web Conference 2025*, 2025, pp. 2032–2042.

[21] M. Wan, T. Safavi, S. K. Jauhar, Y. Kim, S. Counts, J. Neville, S. Suri, C. Shah, R. W. White, L. Yang *et al.*, "Tnt-llm: Text mining at scale with large language models," in *Proceedings of the 30th ACM SIGKDD conference on knowledge discovery and data mining*, 2024, pp. 5836–5847.

[22] Q. Ma, W. Peng, C. Yang, H. Shen, K. Koedinger, and T. Wu, "What should we engineer in prompts? training humans in requirement-driven llm use," *ACM Transactions on Computer-Human Interaction*, 2025.

[23] X. Cai, F. Nie, and H. Huang, "Multi-view k-means clustering on big data." in *IJCAI*, vol. 13, 2013, pp. 2598–2604.

[24] Y.-Z. Lin, S. Ghimire, A. Nandimandalam, J. M. Camacho, U. Tripathi, R. Macwan, S. Shao, S. Rafatirad, R. Yasaei, P. Satam *et al.*, "Llm-hypz: Hardware vulnerability discovery using an llm-assisted hybrid platform for zero-shot knowledge extraction and refinement," *arXiv preprint arXiv:2509.00647*, 2025.

[25] J. White, Q. Fu, S. Hays, M. Sandborn, C. Olea, H. Gilbert, A. Elnashar, J. Spencer-Smith, and D. C. Schmidt, "A prompt pattern catalog to enhance prompt engineering with chatgpt," *arXiv preprint arXiv:2302.11382*, 2023.

[26] OpenAI, "Openai python sdk." [Online]. Available: https://platform.openai.com/docs/api-reference/introduction?lang=python

[27] P. Mithun, E. Noriega-Atala, N. Merchant, and E. Skidmore, "Ai-verde: A gateway for egalitarian access to large language model-based resources for educational institutions," *arXiv preprint arXiv:2502.09651*, 2025.

[28] M. A. Syakur, B. K. Khotimah, E. M. Rochman, and B. D. Satoto, "Integration k-means clustering method and elbow method for identification of the best customer profile cluster," in *IOP conference series: materials science and engineering*, vol. 336. IOP Publishing, 2018, p. 012017.

[29] L. Van der Maaten and G. Hinton, "Visualizing data using t-sne." *Journal of machine learning research*, vol. 9, no. 11, 2008.

[30] MITRE, "2025 cwe most important hardware weaknesses," Aug 2025. [Online]. Available: https://cwe.mitre.org/topHW/archive/2025/2025_CWE_MIHW.html